

Sprint 2 – Group Meeting Notes

Meeting Schedule with mentor (Steve)

- Sprint-2_Meeting-Notes: January 06 – January 19, 2026
- **Meeting Type:** Group meetings with mentor
- **Project:** Open Energy Dashboard (OED)

Role Assignment

- Andrew Bonner

General Update

During Sprint 2, we met with our **mentor** for both group meetings. These meetings focused on reviewing progress, clarifying technical decisions, and getting feedback on security-related issues. Overall, the sprint went smoothly, and the team has a better understanding of expectations and workflow.

Postgres & Database Security

We discussed how OED handles the Postgres database password and potential security concerns.

- The Postgres password is currently stored in an environment file.
- Changing or randomizing the password at startup caused issues because:
 - Environment variables do not reload automatically.
 - Changes to package.json or Docker configuration require a restart.
- Ideas discussed with the mentor:
 - Attempt to reload environment variables without restarting containers.
 - If reloading is not possible, clearly document that a restart is required after password changes.
 - Separate startup behavior from a manual password-change script.
- The mentor emphasized avoiding solutions that could break a production system.

Next Step: Investigate whether environment variables can be reloaded. If not, document restart requirements clearly.

Parameter Validation & Route Testing (PR #1528)

The mentor reviewed improvements made to parameter validation and testing.

- Fixed incorrect validators (e.g., `bool` → `boolean`).
- Added missing validation for strings, arrays, and numeric ranges.
- Added a large automated test suite to ensure future changes don't reintroduce vulnerabilities.
- Tests were hitting rate limits due to speed.
 - Solution: Increase rate limits when `NODE_ENV=test`.

Mentor Feedback:

- Automated testing is preferred over only manual testing (e.g., Burp Suite).
- Manual testing is still useful, but CI tests provide long-term protection.

Login Rate Limiting & Security (Issue #12 / #1564)

We discussed improving security for login attempts.

- Current work includes:
 - Adding rate limiting to login routes.
 - Preventing brute-force attacks.
- Challenges:
 - Automated tests currently bypass rate limits.
- Mentor suggested:
 - Aligning new tests with existing testing infrastructure.
 - Pushing more complex testing work to the next sprint if needed.

Static Analysis Findings (PR #1559 – Semgrep)

Static analysis reported a possible path traversal vulnerability.

- Manual testing could not reproduce the issue.
- After reviewing the code:

- File paths are hard-coded.
- Users do not control file paths.
- Mentor explained that:
 - Static analysis tools often flag theoretical issues.
 - Some warnings are not exploitable in practice.

Decision: Add an explanation comment to the pull request and proceed.

Error Handling & Logging

The mentor emphasized best practices for error handling.

- Detailed errors should remain in logs (admin use only).
- User-facing messages should be simple and non-revealing.
- Development and production modes should handle errors differently.

CI / CD Discussion

- OED uses **continuous integration**, not automatic deployment.
- CI runs through GitHub Actions (.github directory).
- An old Travis configuration exists but is no longer active.
- Some CI/CD work is being done separately to meet class requirements.
- No changes needed for OED's current CI setup.

Pull Requests & Workflow

- **PR #1544:** Needs cleanup due to accidental CI changes.
- **PR #1554:** Added support for manually changing Postgres and OED user passwords.
- Mentor reminded the team:
 - Always fully complete pull request templates.
 - Reference older PRs when replacing or continuing work.

Sprint Reflection

- Sprint 2 feedback was mostly **neutral to positive**.
- Team feels more comfortable with the project structure.
- Learning is happening, especially around security and testing.
- No major concerns about workload or communication.

Next Steps

- Continue security-related work in **Sprint 3**, including:
 - Login rate limiting
 - Password handling improvements
 - Finalizing and reviewing open pull requests